

GLOBALRAIN

Practices for Secure Software Report

Table of Contents

DOCUMENT REVISION HISTORY 3
CLIENT 3
INSTRUCTIONS 3
DEVELOPER 4
1. ALGORITHM CIPHER 4
2. CERTIFICATE GENERATION 5
3. DEPLOY CIPHER 5
4. SECURE COMMUNICATIONS 6
5. SECONDARY TESTING 7
6. FUNCTIONAL TESTING 9
7. SUMMARY 9
8. INDUSTRY STANDARD BEST PRACTICES 10

Document Revision History

Version	Date	Author	Comments
1.0	[Date]	[Your Name]	

Client



Instructions

Developer

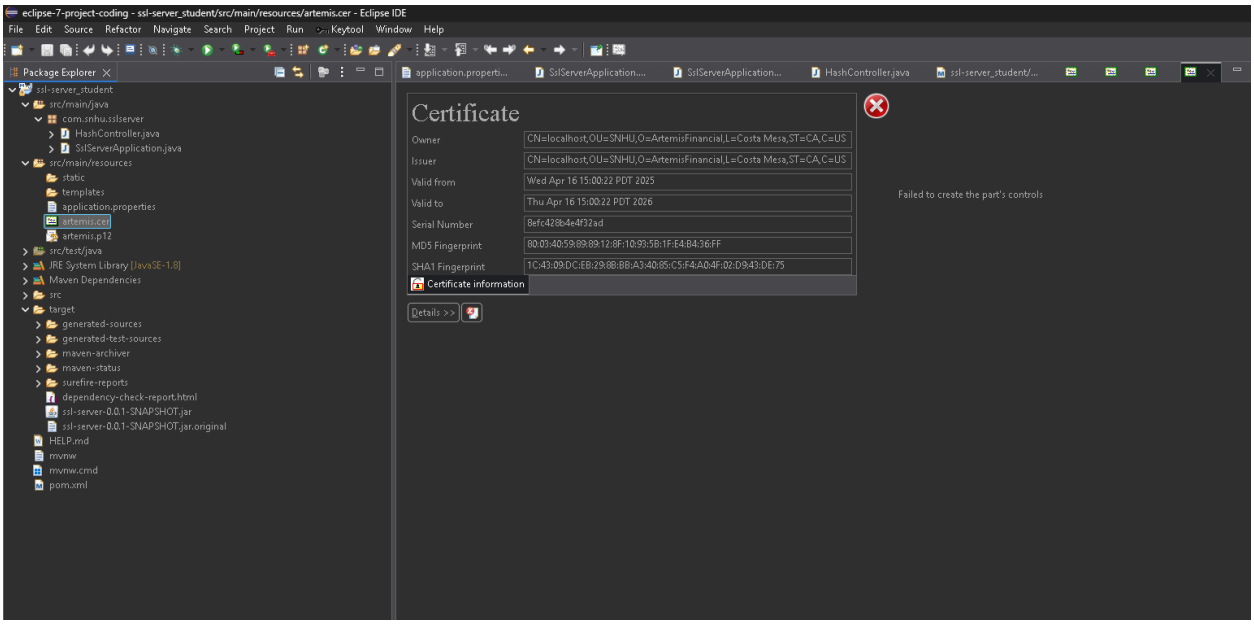
Filip Arghir

1. Algorithm Cipher

For this software I implemented SHA-256 which is widely used and trusted as a cryptographic hash function and generates checksum that verifies the integrity of a static message. Artemis Financial would like security to ensure that data has not be tampered with during any form of transmission and therefore SHA-256 provides a great way to go about this. By using a one-way function like SHA-256 the system can ensure that the original message remains unchanged and is critical for maintaining data accuracy and have secure communications. While AES-256 does exist and is a symmetric design which means that it can help with securing confidentiality and allows data to be encrypted and then decrypted after transmission but does not fit our application therefore we want to ensure that data has not been modified and SHA-256 is preferred due to its speed, and data integrity. SHA-256 also operates on a 512-bit block and outputs a 256-bit hash and therefore does not require any keys as well and therefore renders a 64-character hexadecimal and ensures that it is designed so that no two hashes are the same and that these are ideal for integrity of messages and data. SHA-256 also is a part of the SHA-2 family which was created by NSA in 2001 and is a part of the SHA-2 family of algorithms according to Rhodes.(SHA-256 Cryptographic hash algorithm) The SHA family consisted of a hashing function that was 160 bit and to have a more robust system SHA2 was developed, which is the forefather of sha-256 since they are simply different bit lengths. SHA-256 as its core aims to provide data integrity and authenticity, every hash output will be at a fixed length of 256 bits and in turn is used for transaction security. (Das, Difference Between AES and SHA256)

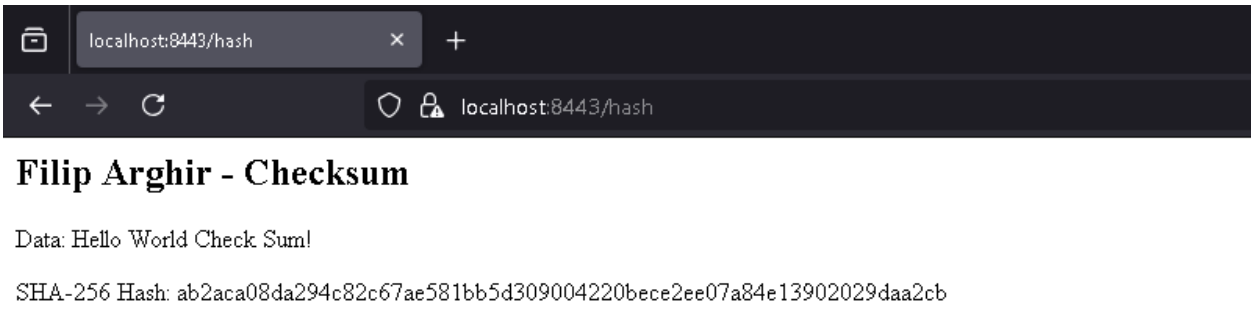
2. Certificate Generation

Insert a screenshot below of the CER file.



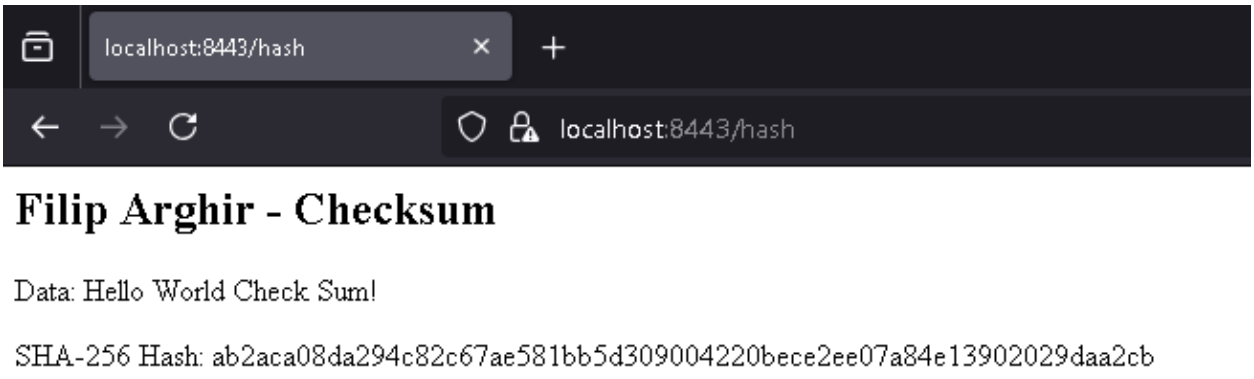
3. Deploy Cipher

Insert a screenshot below of the checksum verification.



4. Secure Communications

Insert a screenshot below of the web browser that shows a secure webpage.



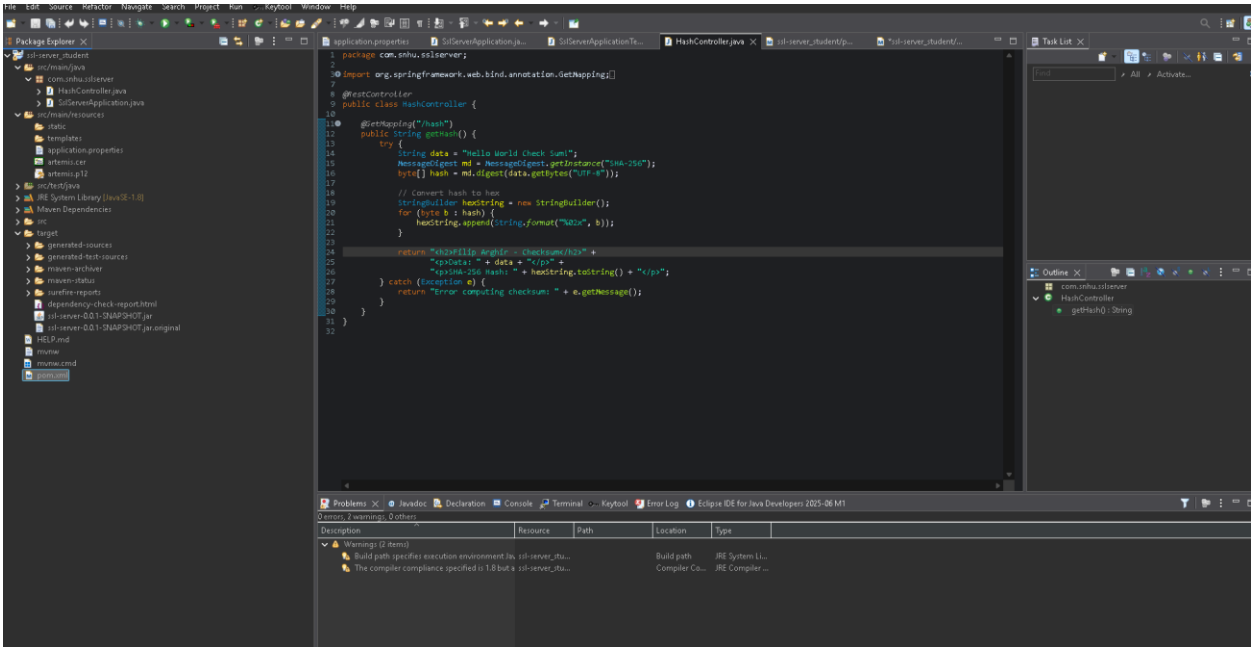
My certificate is functional and attached properly, however since I am not a true organization my https will of course say not secure. I was in fact worried about this, refactored, reinstalled my project a couple of times till further research shows that even when importing my

own certificate and even assigning it to local host this will still occur because I am not a true authority.



5. Secondary Testing

Insert screenshots below of the refactored code executed without errors and the dependency-check report.



Project: ssl-server

com.snhu:ssl-server:0.0.1-SNAPSHOT

Scan Information (show less):

- *dependency-check version*: 5.3.0
- *Report Generated On*: Wed, 16 Apr 2025 15:04:10 -0700
- *Dependencies Scanned*: 49 (35 unique)
- *Vulnerable Dependencies*: 19
- *Vulnerabilities Found*: 149
- *Vulnerabilities Suppressed*: 0
- *CurrentEngineRelease*: 12.1.0
- *NVD CVE Checked*: 2025-04-16T15:04:06
- *NVD CVE Modified*: 2025-04-16T13:00:02
- *VersionCheckOn*: 2025-04-16T15:04:06

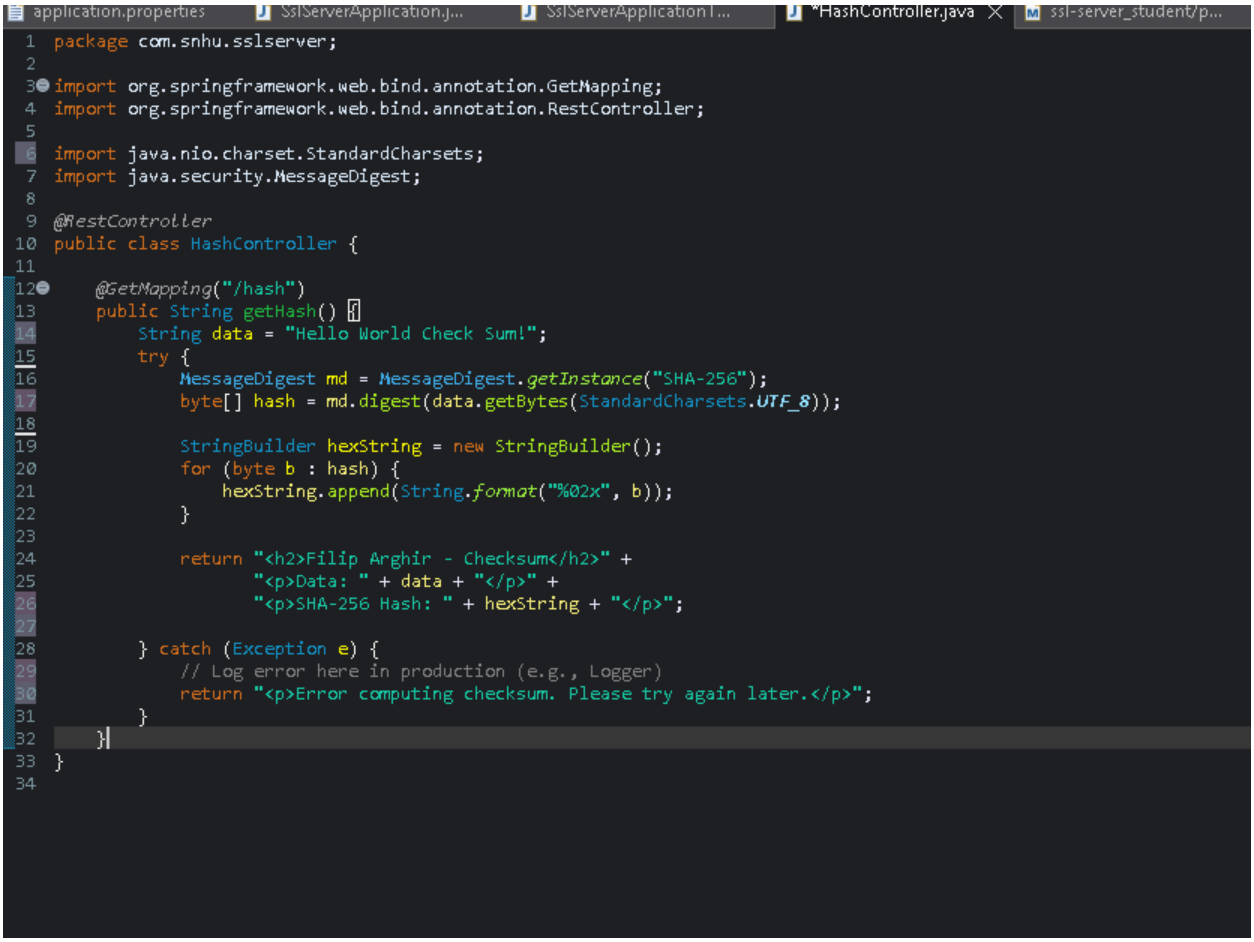
Summary

Display: Showing Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
spring-boot-starter-data-rest-2.2.4.RELEASE.jar	cpe:2.3:a:vmware:spring_boot:2.2.4:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_data_rest:2.2.4:release:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-starter-data-rest@2.2.4.RELEASE	CRITICAL	3	Highest	28
spring-data-rest-webmvc-3.2.4.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_data_rest:3.2.4:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_data_rest:3.2.4:release:*:*:*:*:*:*	pkg:maven/org.springframework.data/spring-data-rest-webmvc@3.2.4.RELEASE	MEDIUM	2	Highest	29
spring-tx-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-tx@5.2.3.RELEASE	CRITICAL	12	Highest	28
spring-hateoas-1.0.3.RELEASE.jar	cpe:2.3:a:vmware:spring_framework:1.0.3:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_hateoas:1.0.3:release:*:*:*:*:*:*	pkg:maven/org.springframework.hateoas/spring-hateoas@1.0.3.RELEASE	CRITICAL	11	Highest	29
jackson-databind-2.10.2.jar	cpe:2.3:a:fasterxml:jackson-databind:2.10.2:*:*:*:*:*:*:*	pkg:maven/com.fasterxml.jackson.core/jackson-databind@2.10.2	HIGH	6	Highest	39
spring-boot-2.2.4.RELEASE.jar	cpe:2.3:a:vmware:spring_boot:2.2.4:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:2.2.4:release:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot@2.2.4.RELEASE	CRITICAL	13	Highest	32
spring-boot-starter-logging-2.2.4.RELEASE.jar	cpe:2.3:a:vmware:spring_boot:2.2.4:release:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-starter-logging@2.2.4.RELEASE	CRITICAL	3	Highest	28
logback-classic-1.2.3.jar	cpe:2.3:a:qos:logback:1.2.3:*:*:*:*:*:*:*	pkg:maven/ch.qos.logback/logback-classic@1.2.3	HIGH	2	Highest	32
logback-core-1.2.3.jar	cpe:2.3:a:qos:logback:1.2.3:*:*:*:*:*:*:*	pkg:maven/ch.qos.logback/logback-core@1.2.3	HIGH	4	Highest	32
log4j-api-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.12.1	CRITICAL	5	Highest	46
snakeyaml-1.25.jar	cpe:2.3:a:snakeyaml_project:snakeyaml:1.25:*:*:*:*:*:*:* cpe:2.3:a:yaml_project:yaml:1.25:*:*:*:*:*:*:*	pkg:maven/org.yaml/snakeyaml@1.25	CRITICAL	10	Highest	28
tomcat-embed-core-9.0.30.jar	cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@9.0.30	CRITICAL	29	Highest	39
hibernate-validator-6.0.18.Final.jar	cpe:2.3:a:redhat:hibernate_validator:6.0.18:*:*:*:*:*:*:*	pkg:maven/org.hibernate.validator/hibernate-validator@6.0.18.Final	MEDIUM	2	Highest	36
spring-web-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-web@5.2.3.RELEASE	CRITICAL	16	Highest	28
spring-webmvc-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-webmvc@5.2.3.RELEASE	CRITICAL	13	Highest	30
spring-expression-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-expression@5.2.3.RELEASE	CRITICAL	13	Highest	30
json-path-2.4.0.jar	cpe:2.3:a:json-path:jayway_jsonpath:2.4.0:*:*:*:*:*:*:*	pkg:maven/com.jayway.jsonpath/json-path@2.4.0	MEDIUM	1	Highest	30
json-smart-2.3.jar	cpe:2.3:a:json-smart_project:json-smart:2.3:*:*:*:*:*:*:*	pkg:maven/net.minidev/json-smart@2.3	HIGH	3	Highest	34
accessors-smart-1.2.jar	cpe:2.3:a:json-smart_project:json-smart:1.2:*:*:*:*:*:*:*	pkg:maven/net.minidev/accessors-smart@1.2	HIGH	1	Low	30

6. Functional Testing

Insert a screenshot below of the refactored code executed without errors.



7. Summary

In this project I refactored the code for Artemis Financial and ensured that this application follows the request of Artemis. I refactored the code to focus on data integrity by utilizing SHA-256 a cryptographic hash function that ensures data has not been tampered with. I also ensured that the refactored code caused no extra vulnerabilities this system has been employed to ensure that the code refactored is not the cause of any issues but instead other areas. I focused on also implementing a system that does data integrity checks and helps simplify the system. This code

originally had some exception handling issues and was tested to ensure that this code does execute properly without errors. My refactored code also swapped from exception messages that were directly to the suer but instead replaced with generic errors to help prevent any leaks and malicious attacks. I also use a safe input method to ensure that inputs can be sanitized and validated for hash generation. UTF-8 is another part of this refactored code that can cause issues and therefore using standardCharsets.utf_8 ensures that my system remains reliable and that unique characters cause no issues.

8. Industry Standard Best Practices

Some industry standards this I followed was secure exception handling to ensure that internal errors give generic codes to attackers, clean encoding practices with consistent usage and very readable code that can be easily worked on if this was to be taken on by other personnel. Applying secure coding can reduce the amount of attacks or even a reason for attacks. Having security at every step of the way ensures that it is harder for attackers to abuse any vulnerabilities. This also helps with trust, having a history of defense means that more stakeholders, users, coworkers, are all honored and happy to be apart of a secure system. Standards also exist and therefore following industry standard ensures that a system can stay secure for longer or even help change the standard.

Refrences

Das, D. (2023, October 10). *Difference Between AES and SHA256*. Medium. https://diptendud.medium.com/difference-between-aes-and-sha256-706d6b2eb2ef

Rhodes, D. (2020, April 27). *SHA-256 Cryptographic Hash Algorithm*. Komodo Academy | En. https://komodoplatform.com/en/academy/sha-256-algorithm/

Squirrel, S. the S. (2023, July 27). *Unlocking the Power of AES-256 Encryption: Symmetric vs Asymmetric for Diverse Industry Enterprises*. Kiteworks | Your Private Content Network. https://www.kiteworks.com/cybersecurity-risk-management/unlocking-the-power-of-aes-256-encryption-symmetric-vs-asymmetric-for-diverse-industry-enterprises/